1.3.5 Artificial intelligence

The advent of GenAI, and particularly AI agents that can act on a person’s behalf, pours gasoline on the smoldering interest in authorization by organizations. Am I talking to a human? Does this agent have the authority to make a doctor's appointment on the patient's behalf? These and other questions mean that making good authorization decisions, knowing what decisions were made, and easily incorporating authorization infrastructure into your apps and infrastructure is vital.

AI applications are often built by augmenting the foundational capabilities of the large language model (LLM) with other data for a specific application. For example, an AI application built to aid financial analysts asking about an organization’s finances may need to add information specific to the organization’s financial records. The underlying model is augmented with the financial records it needs, an approach called Retrieval Augmented Generation (RAG). This presents an authorization challenge: different users of the application should only see answers consistent with the financial records that they’re entitled to see. RAG architectures can be built with dynamic authorization in place to prevent unauthorized access to data by people using the application. We’ll discuss this topic in detail in chapter 17.

GenAI is still in the early stages of being commercialized, but underpinning it with strong, fine-grained access control can give it the capabilities to properly protect sensitive information.

1.4 Dynamic authorization: Policy as Code and Policy as Data

Dynamic authorization depends on making real-time, context-aware access control decisions by evaluating policies at runtime instead of relying on static, pre-configured permissions or special-purpose code. A key distinction from earlier approaches is that policies are represented so that a common, general-purpose engine can use them to make access decisions. There are two different, complementary methods of representing policy: